COM/BLM 426
BİLGİ GÜVENLİĞİ

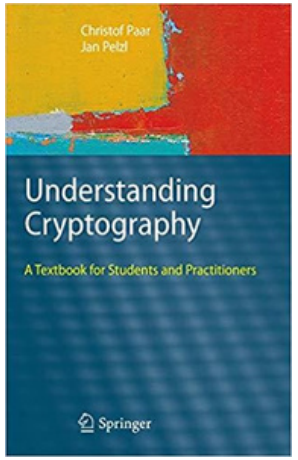
Asst. Prof. Dr. Bulent TUGRUL
btugrul@eng.ankara.edu.tr

Slides are mainly based on:

Understanding Cryptography: A Textbook for Students and Practitioners

by ChristofPaarand Jan Pelzl

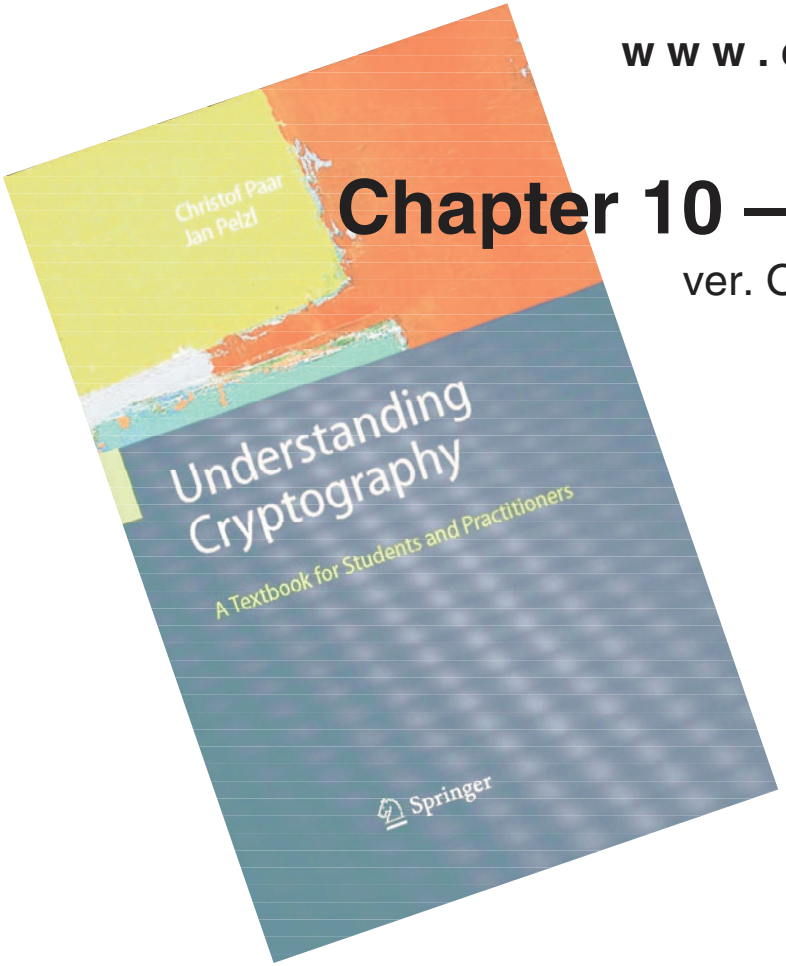
Springer, 1st Edition, 2010



Understanding Cryptography –A Textbook for Students and Practitioners

by Christof Paar and Jan Pelzl

w w w . crypto-textbook. com



Chapter 10 – Dijital İmzalar

ver. October 29, 2009

These slides were prepared by Georg Becker, Christof Paar and Jan Pelzl

Bazı yasal bilgiler (sorry): Kullanım Şartları

- Slaytlar ücretsiz olarak kullanılabilir. Slaytların tüm telif hakları Christof Paar ve Jan Pelzl'e aittir.

- Eşlik eden "Understanding Cryptography" kitabının başlığı (Springer tarafından) ve yazarların isimleri her slaytta yer almalıdır.

- Slaytlar değiştirilirse, kitap yazarlarına ve kitap başlığına ilişkin uygun atıflar slaytlarda yer almalıdır.

- Yazarların yazılı izni olmadan slaytların tamamının veya bir kısmının basılı olarak çoğaltılmasına izin verilmez.

Bu Bölümün İçeriği

- Dijital imzaların prensibi
- Güvenlik hizmetleri
- RSA dijital imza şeması
- Dijital İmza Algoritması (DSA)

Bu Bölümün İçeriği

- **Dijital imzaların prensibi**
- Güvenlik hizmetleri
- RSA dijital imza şeması
- Dijital İmza Algoritması (DSA)

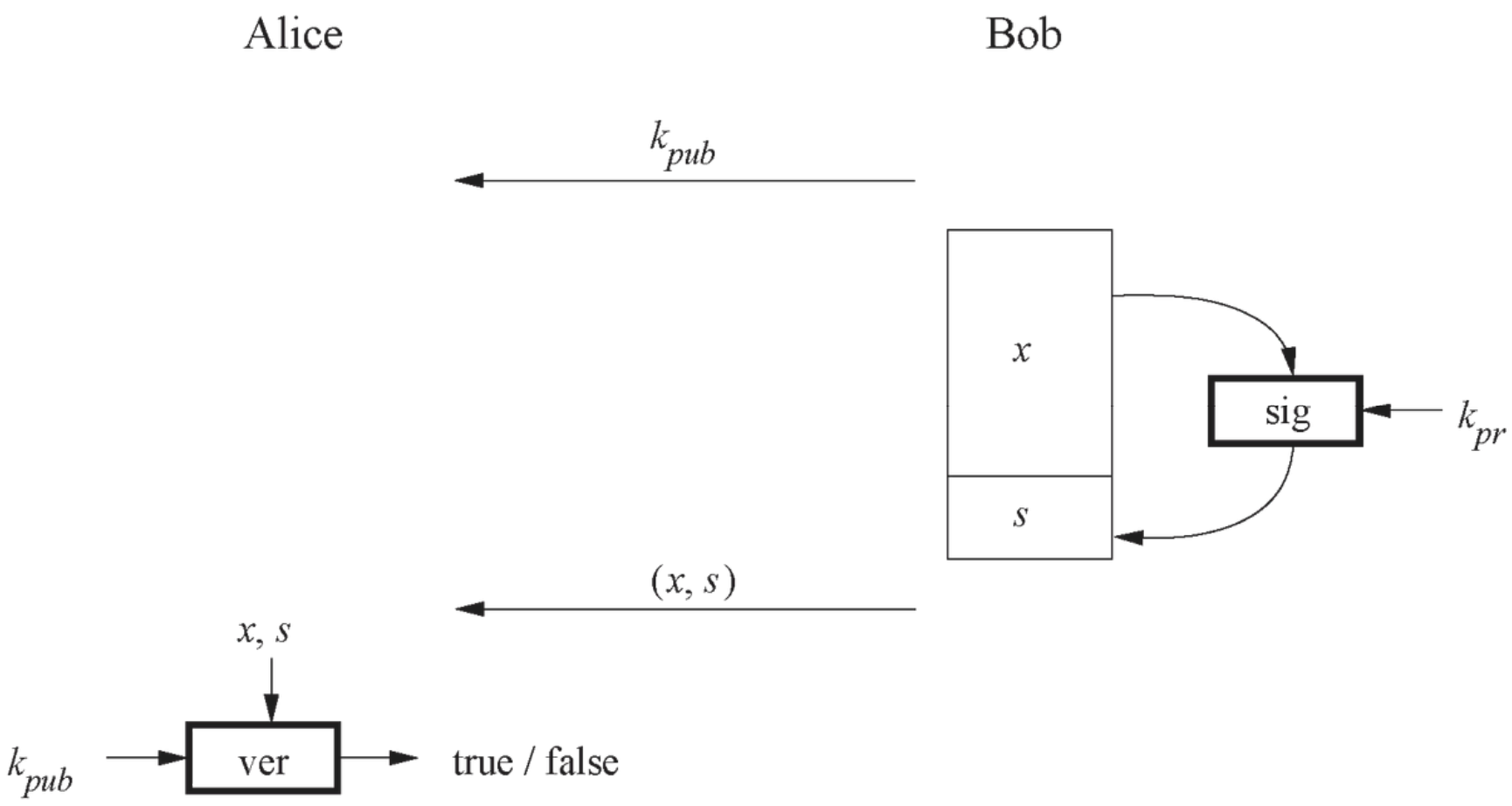
Motivasyon

- Alice, araba satıcısı Bob'tan pembe bir araba sipariş eder.
- Pembe arabayı gördükten sonra Alice, onu asla sipariş etmediğini belirtiyor:
- Bob, Alice'in pembe bir araba sipariş ettiğini (ve siparişi kendisinin uydurmadığını) bir hakime nasıl kanıtlayabilir?

  $\Rightarrow$ Simetrik şifreleme başarısız olur çünkü hem Alice hem de Bob kötü niyetli olabilir

  $\Rightarrow$ Açık anahtarlı şifreleme ile gerçekleştirilebilir

Dijital İmzaların Temel Prensibi



Ana fikir

- Verilen bir x mesajı için, mesaja dijital bir imza eklenir (tıpkı geleneksel bir imza gibi).
- İmzayı yalnızca özel anahtara sahip olan kişi oluşturabilmelidir.
- İmza her belge için değişmelidir.

$\Rightarrow$ İmza, girdi olarak x mesajı ve özel anahtarı alan bir fonksiyon olarak gerçekleştirilir.

$\Rightarrow$ Açık anahtar ve x mesajı, doğrulama fonksiyonunun girdileridir.

Bu Bölümün İçeriği

- Dijital imzaların prensibi
- **Güvenlik hizmetleri**
- RSA dijital imza şeması
- Dijital İmza Algoritması (DSA)

Temel Güvenlik Hizmetleri

Güvenlik sistemlerinin hedeflerine **güvenlik *hizmetleri*** *denir.*

1. **Gizlilik:** Bilgiler, yetkili kişiler dışında herkesten gizli tutulur.

2. **Bütünlük:** Bir mesajın iletim sırasında değiştirilmediğini garanti eder.

3. **Mesaj Kimlik Doğrulaması:** Bir mesajın göndericisinin kimliğinin doğrulanmasını sağlar. Alternatif bir terim olarak veri kaynağı kimlik doğrulaması da denir.

4. **İnkar edilemezlik:** Mesaj göndericisinin mesajın oluşturulduğunu inkar edememesini sağlar. (Örneğin, pembe araba siparişi).

Ek Güvenlik Hizmetleri

5. **Kimlik tespiti/varlık doğrulama:** Bir varlığın, örneğin bir kişinin, bir bilgisayarın veya bir kredi kartının kimliğinin belirlenmesi ve doğrulanması.
6. **Erişim kontrolü:** Kaynaklara erişimi yalnızca ayrıcalıklı varlıklarla sınırlandırmak.
7. **Erişilebilirlik:** Elektronik sistem güvenilir bir şekilde kullanılabilir durumdadır.
8. **Denetim:** Güvenlikle ilgili faaliyetler hakkında kanıt sağlar, örneğin belirli olaylar hakkında kayıtlar tutarak.
9. **Fiziksel güvenlik:** Fiziksel müdahaleye karşı koruma sağlamak ve/veya fiziksel müdahale girişimlerine karşı önlem almak.
10. **Anonimlik:** Kimliğin keşfedilmesine ve kötüye kullanılmasına karşı koruma sağlamak.

Bu Bölümün İçeriği

- Dijital imzaların prensibi
- Güvenlik hizmetleri
- **RSA dijital imza şeması**
- Dijital İmza Algoritması (DSA)

RSA imza şemasının temel fikri

Özel ve açık anahtarı oluşturmak için:

- RSA şifrelemesinde kullanılan anahtar oluşturma yöntemini kullanın.

İmzayı oluşturmak için:

- x mesajını özel anahtarla "şifreleyin"

$$s = sig_{K_{priv}}(x) = x^d \bmod n$$

- s'yi x mesajına ekle

İmzayı doğrulamak için:

- İmzayı açık anahtarla "şifresini çözün"

$$x' = ver_{K_{pub}}(s) = s^e \bmod n$$

- Eğer x=x' ise, imza geçerlidir

RSA İmza Protokolü

Alice

Bob

K_{pub} ←

$K_{pr} = d$
$K_{pub} = (n, e)$

İmzayı hesapla:

$s = sig_{k_{pr}}(x) \equiv x^d \bmod n$

(x,s) ←

İmzayı doğrulayın:

$x' \equiv s^e \bmod n$
If $x' \equiv x \bmod n \rightarrow$ geçerli imza
If $x' \not\equiv x \bmod n \rightarrow$ geçersiz imza

RSA İmza Şemasının Güvenliği ve Performansı

Security:

RSA şifrelemesiyle aynı kısıtlamalar geçerlidir: 80 bitlik bir güvenlik seviyesi sağlamak için n'nin en az 1024 bit olması gerekir.

⇒ S karakterlerinden oluşan imzanın en az 1024 bit uzunluğunda olması gerekir.

Performans:

İmzalama işlemi özel anahtarla üs alma, doğrulama işlemi ise açık anahtarla üs alma işlemidir.

⇒ İmza doğrulama, açık anahtar için az sayıda değer seçilebildiği için oldukça verimlidir.

RSA Dijital İmzasına Karşı Varoluşsal Sahtecilik Saldırısı

Alice	Oscar	Bob
		$K_{pr} = d$ $K_{pub} = (n, e)$
$\xleftarrow{(n,e)}$		$\xleftarrow{(n,e)}$
	1. İmza seçin: $s \in Z_n$	
	2. Hesaplama mesajı: $x \equiv s^e \bmod n$	
$\xleftarrow{(x,s)}$		

Doğrulama:

$s^e \equiv x' \bmod n$

bu yana $s^e = (x^d)^e \equiv x \bmod n$

$\rightarrow$ İmza geçerlidir.

Varoluşsal Sahtekarlık ve Dolgu

- Bir saldırgan geçerli mesaj-imza çiftleri (x,s) oluşturabilir.
- Ancak bir saldırı yalnızca imzayı (s) seçebilir, mesajı (x) seçemez.

$\Rightarrow$ Saldırgan, "Oscar'ın hesabına 1000 dolar transfer et" gibi mesajlar oluşturamaz.

Mesaj x'i bir dolgu şemasına göre biçimlendirmek, bir saldırganın geçerli (x,s) çiftleri oluşturamamasını sağlamak için kullanılabilir.

(Varoluşsal Sahtecilik Saldırısı sırasında bir saldırgan tarafından oluşturulan x mesajı, dolgu şemasıyla örtüşmeyecektir. Daha fazla ayrıntı için Understanding Cryptography kitabının 10. Bölümüne bakın.)

Bu Bölümün İçeriği

- Dijital imzaların prensibi
- Güvenlik hizmetleri
- RSA dijital imza şeması
- **Dijital İmza Algoritması (DSA)**

Dijital İmza Algoritması (DSA) Hakkında Bilgiler

- ABD Federal Hükümeti'nin dijital imzalar için standardı (DSS)
- Ulusal Standartlar ve Teknoloji Enstitüsü (NIST) tarafından önerilmiştir
- DSA, Elgamal imza şemasına dayanmaktadır
- İmza yalnızca 320 bit uzunluğundadır
- İmza doğrulaması RSA'ya kıyasla daha yavaştır

Dijital İmza Algoritması (DSA)

DSA'nın temel üretimi:

1. $2^{1023} < \boldsymbol{p} < 2^{1024}$ koşulunu sağlayan bir asal sayı p üretin
2. $2^{159} < \boldsymbol{q} < 2^{160}$ koşulunu sağlayan p-1'in bir asal böleni q bulun
3. ord(α)=q koşulunu sağlayan bir tam sayı α bulun
4. 0 < d < q koşulunu sağlayan rastgele bir tam sayı d seçin
5. $\beta \equiv \alpha^d \bmod p$ değerini hesaplayın

Anahtarlar şunlardır:

$$k_{pub} = (p, q, \alpha, \beta)$$

$$k_{pr} = (d)$$

Dijital İmza Algoritması (DSA)

DSA imza oluşturma:

Verilenler: mesaj x, imza s, özel anahtar d ve açık anahtar (p,q,α,β)

1. $0<k_E<q$ koşulunu sağlayan rastgele bir geçici anahtar k_E tamsayısı seçin
2. $r \equiv (\alpha^{k_E} \bmod p) \bmod q$ 'yu hesaplayın
3. $s \equiv (SHA(x)+d \cdot r)\, k_E^{-1}$ 'yu hesaplayın

İmza (r,s)'den oluşur

SHA, x mesajının 160 bitlik parmak izini hesaplayan SHA-1 karma fonksiyonunu ifade eder. (Daha fazla ayrıntı için Understanding Cryptography kitabının 11. Bölümüne bakınız.)

Dijital İmza Algoritması (DSA)

DSA imza doğrulaması

Verilenler: mesaj x, imza s ve açık anahtar (p,q,α,β)

1. Yardımcı değer $w \equiv s^{-1} \bmod q$ 'yu hesaplayın
2. Yardımcı değer $u_1 \equiv w \cdot SHA(x) \bmod q$ 'yu hesaplayın
3. Yardımcı değer $u_2 \equiv w \cdot r \bmod q$ 'yu hesaplayın
4. $v \equiv (\alpha^{u1} \cdot \beta^{u2} \bmod p) \bmod q$ 'yu hesaplayın

Eğer If $v \equiv r \bmod q \rightarrow$ ise imza geçerlidir

Eğer If $v \not\equiv r \bmod q \rightarrow$ ise imza geçersizdir

DSA'nın Kanıtı:

(r,s) imzasının aslında r ≡ v mod q koşulunu sağladığını göstermemiz gerekiyor:

$$s \equiv (\mathrm{SHA}(x)) + d \cdot r) \cdot k_E^{-1} \bmod q$$

$$\Leftrightarrow \quad k_E \equiv s^{-1}\,\mathrm{SHA}(x) + d \cdot s^{-1}\, r \bmod q$$

$$\Leftrightarrow \quad k_E \equiv u_1 + d \cdot u_2 \bmod q$$

Eğer p modülüne göre indirgersek, α'yı denklemin her iki tarafına da yükseltebiliriz:

$$\Leftrightarrow \quad \alpha^{k_E} \bmod p \equiv \alpha^{u_1 + d \cdot u_2} \bmod p$$

$\beta \equiv \alpha^d \bmod p$ olduğundan şunu yazabiliriz:

$$\Leftrightarrow \quad \alpha^{k_E} \bmod p \equiv \alpha^{u_1} \beta^{u_2} \bmod p$$

Şimdi denklemin her iki tarafını da q modülüne göre sadeleştiriyoruz:

$$\Leftrightarrow \quad (\alpha^{k_E} \bmod p) \bmod q \equiv (\alpha^{u_1} \beta^{u_2} \bmod p) \bmod q$$

$r \equiv \alpha^{k_E} \bmod p \bmod q$ and $v \equiv (\alpha^{u_1} \beta^{u_2} \bmod p) \bmod q$,

olduğundan, bu ifade aşağıdakiyle aynıdır:

$$\Leftrightarrow \quad r \equiv v$$

Örnek

Alice | Bob

Anahtar oluşturma:

1. seçin $p = 59$ ve $q = 29$
2. seçin $\alpha = 3$
3. özel anahtarı seçin $d = 7$
4. $\beta = \alpha^{\beta} = 3^7 \equiv 4 \bmod 59$

$\xleftarrow{(p,\ q,\ \alpha,\ \beta)=(59,\ 29,\ 3,\ 4)}$

Hesaplama mesajı içerir $H(x)=26$

1. Geçici anahtarı seçin $k_E=10$
2. $r = (3^{10} \bmod 59) \equiv 20 \bmod 29$
3. $s = (26 + 7 \cdot 20) \cdot 3) \equiv 5 \bmod 29$

$\xleftarrow{(x,(r,\ s))=(x,20,\ 5)}$

Doğrulamak:

$w \equiv 5^{-1} \equiv 6 \bmod 29$

$u_1 \equiv 6 \cdot 26 \equiv 11 \bmod 29$

$u_2 \equiv 6 \cdot 20 \equiv 4 \bmod 29$

$v = (3^{11} \cdot 4^4 \bmod 59) \bmod 29 = 20$

$v \equiv r \bmod 29 \rightarrow$ geçerli imza

DSA'nın Güvenliği

p'ye göre ayrık logaritma problemini çözmek için güçlü indeks hesaplama yöntemi uygulanabilir. Ancak bu yöntem, q alt grubuna ait ayrık logaritma problemine uygulanamaz.
Bu nedenle q, p'den küçük olabilir. Ayrıntılar için Understanding Cryptography kitabının 10. ve 8. bölümlerine bakınız.

p	q	hash output (min)	güvenlik seviyeleri
1024	160	160	80
2048	224	224	112
3072	256	256	128

DSA için standartlaştırılmış parametre bit uzunlukları ve güvenlik seviyeleri.

Eliptik Eğri Dijital İmza Algoritması (ECDSA)

- Eliptik Eğri Kriptografisi (ECC) tabanlıdır
- 1024-3072 bit RSA'ya (80-128 bit simetrik güvenlik seviyesi) eşdeğer güvenlik sağlamak için 160-256 bit aralığında bit uzunlukları seçilebilir
- Bir imza iki noktadan oluşur, bu nedenle imza kullanılan bit uzunluğunun iki katıdır (yani, 80-128 bit güvenlik seviyesi için 320-512 bit)
- ECDSA'nın daha kısa bit uzunluğu genellikle daha kısa işlem süresiyle sonuçlanır

Daha fazla ayrıntı için Understanding Cryptography adlı kitabın 10.5. bölümüne bakınız.

Öğrenilen Dersler

- Dijital imzalar mesaj bütünlüğü, mesaj kimlik doğrulaması ve inkar edilemezlik sağlar.
- RSA şu anda en yaygın kullanılan dijital imza algoritmasıdır.
- Rakipleri Dijital İmza Standardı (DSA) ve Eliptik Eğri Dijital İmza Standardı (ECDSA)'dır.
- RSA doğrulaması kısa açık anahtarlarla yapılabilir. Bu nedenle, pratikte RSA doğrulaması genellikle imzalamadan daha hızlıdır.
- DSA ve ECDSA, RSA'dan daha kısa imzalara sahiptir.
- Belirli saldırıları önlemek için RSA, dolgu ile birlikte kullanılmalıdır.
- DSA ve RSA imza şemalarının modülü en az 1024 bit uzunluğunda olmalıdır. Gerçek uzun vadeli güvenlik için 3072 bit uzunluğunda bir modül seçilmelidir. Buna karşılık, ECDSA aynı güvenlik seviyelerini 160-256 bit aralığındaki bit uzunluklarıyla elde eder.